המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

<u>בחינה בקורס:</u> מבוא לאבטחת סייבר
<u>קוד קורס:</u> 689156
<u>תאריך הבחינה:</u> 04/07/2024 <u>שעת הבחינה:</u> 09:00
<u>שנה"ל:</u> תשפ"ד <u>סמסטר:</u> ב' <u>מועד:</u> ב'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

<u>הוראות לנבחן:</u>

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- יש לסמן את התשובה <u>הנכונה ביותר</u> בדף הקידוד **<u>בעט שחור/כחול בלבד, באופן ברור ומודגש</u>**
- **רק דף הקידוד ייבדק**
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 09:30, 10:00. לזכאי תוספת זמן גם בשעה 10:20

***** חשוב מאוד:**
בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, תשובה א היא התשובה הנכונה

<u>שאלה מספר 1:</u>

תכונת ה second pre image resistance מוגדרת כ:

א. בהינתן הודעה אקראית m, קשה למצוא הודעה 'm ששונה מ m, כך ש h(m) = h(m')

ב. בהינתן digest d של הודעה אקראית, קשה למצוא הודעה m כך ש h(m)=d

ג. בהינתן הודעה אקראית m, קשה למצוא הודעה 'm ששונה מ m, כך ש h(m) שונה מ h(m')

ד. בהינתן digest d של הודעה אקראית, קשה למצוא 'd digest כך ש d שונה מ 'd

<u>שאלה מספר 2:</u>

עבור n=19 ו g=3, אליס ובוב הריצו את פרוטוקול Diffie-Hellman. במהלך הרצת הפרוטוקול, אליס שלחה לבוב את המספר 15 ובוב שלח לה את המספר 5. מה מהבאים יכול להיות המספר הסודי <u>המשותף</u> שנבחר? (כלומר, מה המפתח המשותף שיצא לשניהם בסוף התהליך)

א. 9

ב. 4

ג. 12

ד. 11

<u>שאלה מספר 3:</u>

רוצים לבנות טבלת משתמשים ב DB שתשמור את המידע שישמש להתחברות לאתר. כל אחת מההצעות הבאות מתארת אילו עמודות יהיו בטבלה - כלומר, גם אלו ערכים יהיו בהן.

איזה מבין ההצעות הבאות מציגה שימוש לא נכון ב salt ו/או pepper מבחינה אבטחתית (כלומר, היישום המוצג לא משיג את מטרת חיזוק האבטחה ע"י מנגנונים אלו)?

(h היא פונק' hash והסימן || הוא שרשור)

א. username, salt, h(password) || h(salt || pepper)

ב. username, salt, h(password || salt || pepper)

ג. username, salt, h(password || salt)

ד. username, h(password || pepper)

<u>שאלה מספר 4:</u>

איזו מבין הטענות הבאות נכונה?

א. ב TLS, מנגנון ה chain of trust מאפשר ללקוח הגולש לשרת foo.com לוודא את תקינות התעודה שקיבל כחלק מתהליך הקמת החיבור המוצפן.

ב. ב TLS, משתמשים במפתחות זהים להצפין תעבורה הנשלחת מהשרת ללקוח ותעבורה הנשלחת מהלקוח לשרת.

ג. ב TLS, שרת חייב לוודא את תקינות התעודה של הלקוח לפני השלמת החיבור.

ד. לא ניתן להקים חיבור TLS בלי ביצוע מנגנון Diffie Hellman.

<u>שאלה מספר 5:</u>

איזו טענה <u>אינה</u> נכונה?

א. בהינתן הודעה m להצפנה ומפתחות הצפנה k1,k2,k3 ששונים אחד מהשני, אין הבדל בפלט של 3DES במידה והוא ממומש על ידי הצפנה-הצפנה-הצפנה או הצפנה-פענוח-הצפנה.

ב. בהינתן הודעה m להצפנה ומפתח הצפנה k, ניתן לייצר בעזרת 3DES את אותו הפלט ש DES היה מוציא.

ג. AES הוא דוגמא לצופן בלוקים.

ד. גם ב AES אנחנו צריכים להגדיר את ה mode of operation.

<u>שאלה מספר 6:</u>

מחליטים לבצע שינוי לאופן שבו ביטקוין עובד. השינוי הוא שהחליטו לשנות את פונק׳ ה hash שמשתמשים בה לתהליך ה proof of work.

איזו מבין הטענות הבאות נכונה?

א. זאת דוגמא ל hard fork.

ב. זאת דוגמא ל hashing fork.

ג. זאת דוגמא ל proof of work fork.

ד. זאת דוגמה ל soft fork.

<u>שאלה מספר 7:</u>

איזו טענה <u>אינה</u> נכונה?

א. מנגנון ה Online Certificate Status Protocols (OCSP) משמש miners כחלק מתהליך בדיקת חוקיות של בלוק חדש המיועד להצטרף לבלוקצ'יין.

ב. מנגנון ה OCSP stapling נועד לפתור בעיית פרטיות במנגנון ה OCSP.

ג. מנגנון Certificate Transparency ומנגנון Certificate Revocation List (CRL) פותרים בעיות שונות.

ד. מנגנון Certificate Transparency בא לידי ביטוי ב certificates על ידי ערכי ה Signed Certificate Timestamp (SCT).

<u>שאלה מספר 8:</u>

איזו מבין הטענות הבאות נכונה?

א. הגדרת same site cookie להיות strict מסייע בהגנה מפני התקפת cross-site request forgery.

ב. התקפת cross-site request forgery בנויה על כך שהדפדפן מצרף xss לבקשות.

ג. ב Dom-based XSS החולשה נמצאת בקוד שרץ ב db.

ד. אחת מהדרכים להגן מפני התקפת cross-site request forgery היא בעזרת anti-csrf token. הגנה זאת מבקשת מהמשתמש להזין ידנית קוד מיוחד לשדה הזנת טקסט ייעודי באתר.

<u>שאלה מספר 9:</u>

איזו מבין הטענות הבאות נכונה?

א. בפרוטוקול Address Resolution Protocol (ARP), התקפת הרעלת ARP מסתמכת על כך שאם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה, התשובה האחרונה תדרוס את התשובה הראשונה. ב DNS לעומת זאת, אם מנסים לבצע התקפת הרעלה, אם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה כל אחת עם TTL ארוך, התשובה הראשונה קובעת ולא נדרסת על ידי אלו שבאות אחריה למשך ה TTL.

ב. בפרוטוקול Address Resolution Protocol (ARP), התקפת הרעלת ARP מסתמכת על כך שאם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה, התשובה הראשונה קובעת ולא נדרסת על ידי אלו שבאות אחריה. באופן דומה, ב DNS, אם מנסים לבצע התקפת הרעלה, אם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה כל אחת עם TTL ארוך, התשובה הראשונה קובעת ולא נדרסת על ידי אלו שבאות אחריה למשך ה TTL.

ג. בפרוטוקול Address Resolution Protocol (ARP), התקפת הרעלת ARP מסתמכת על כך שאם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה, התשובה האחרונה תדרוס את התשובה הראשונה. באופן דומה, ב DNS, אם מנסים לבצע התקפת הרעלה, אם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה כל אחת עם TTL ארוך, התשובה האחרונה תדרוס את התשובה הראשונה.

ד. בפרוטוקול Address Resolution Protocol (ARP), התקפת הרעלת ARP מסתמכת על כך שאם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה, התשובה הראשונה קובעת ולא נדרסת על ידי אלו שבאות אחריה. ב DNS לעומת זאת, אם מנסים לבצע התקפת הרעלה, אם הגיעו שתי תשובות שונות ולגיטימיות לאותה שאלה אחת אחרי השניה כל אחת עם TTL ארוך, התשובה האחרונה תדרוס את התשובה הראשונה.

<u>שאלה מספר 10:</u>

בגרסאות מסויימות של דפדפן מוכר, ניתן היה לטעון בתוך iframe לא רק עמודי אינטרנט אחרים, אלא גם את ה "view-source" שלהם, כלומר, להציג ב iframe את ה html של עמוד אינטרנט במקום את התרגום הויזואלי של אותו html. תוקף הצליח לנצל זאת לרעה על ידי שהוא הציג לקורבנות אזור מאוד ספציפי ב html, וביקש מהמשתמשים להזין ולשלוח לתוקף את הטקסט שכתוב באיזור זה, כי לתוקף אין גישה ל html הספציפי שמוצג לקורבנות. בעזרת הטקסט שהקורבנות שלחו לתוקף, הצליח התוקף לעקוף מנגנון הגנה.

באיזה מנגנון הגנה מדובר?

א. Anti CSRF token

ב. קידוד (Encoding)

ג. חיטוי (Sanitization)

ד. Certificate Transparency

--- סוף המבחן ---